SLIIT

Discover Your Future

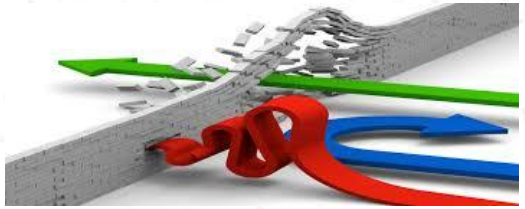
Pen Testing IE3132

Kanishka Yapa

Lecture 2

Penetration Testing & Recon

Penetration Testing



- Penetration testing or ethical hacking is a proactive security assessment
- Tests internal and external systems by simulating an attack
- During testing security specialists review systems security policies and procedures for the goal of reducing overall risk
- This is carried out by a pentester

Importance of Penetration Testing

- To identify the threats and vulnerabilities to organizations assets.
- To provide a comprehensive assessment of policies, procedures, design, and architecture.
- To set remediation actions to secure them before they are used by a hacker to breach security.
- To test and validate the security protection & identify the need for any additional protection layer.

Approaches



- Blue Teaming is an approach, in which a security team is responsible for performing analysis on security control and efficiency of an information security system. They detect and mitigate red team attacks.
- In Red teaming approach a team of ethical hackers or pen testers are responsible for system penetration with limited or without any granted access to system resources. They detect an evaluate vulnerabilities from an attacker's perspective.

Types of Penetration Testing

- Black box testing
  Pentester has no prior knowledge about the system or any information about the target.
- Grey box testing
  Gray box, is a type of penetration testing in which the pentester has very limited prior knowledge of the system or any information of targets such as IP addresses, Operating system or network information in very limited. Gary boxing is designed to demonstrate an emulated situation as an insider might have this information and to counter an attack as the pentester has basic, limited information regarding target.
- White box testing
  The white box is a type of penetration testing in which the pentester has complete knowledge of system and information of the target. This type of penetration is done by internal security teams or security audits teams to perform auditing.

Security Assessments

- Network Devices
- E-mail and Web Interfaces
- Wireless networks
- Applications and Databases

Attack Surfaces



- Software
- Hardware
- Network
- Users

Vulnerability Scanning vs. Pen Testing

	Vulnerability Scan	Pen Testing
Purpose	Identify vulnerabilities.	Attempt to exploit the vulnerabilities.
When	Quarterly or after significant change	Annually or after significant change
How	Automated with manual verification	Manual process that results in a comprehensive final report
Reports	Lengthy reports listing the details, ranked in order of severity	Description of the vulnerabilities and how the weakness could be exploited
Duration	Short – from several seconds to several minutes for each host	May last from a few days to a few weeks

Stages of the Penetration Test

1. Pre-engagement
2. Information-gathering
3. Threat-modeling
4. Vulnerability analysis
5. Exploitation
6. Post-exploitation
7. Reporting

Pre-engagement



- perform pre-engagement interactions with the client to make sure everyone is on the same page about the pen testing.
- Things to look at..
- Take the time to understand your client's business goals for the pentest.
- If this is their first pentest?
- What prompted them to find a pentester?
- What exposures are they most worried about?
- Do they have any fragile devices you need to be careful with when testing?
- What matters most to them?

Other important items to discuss and agree upon during the pre-engagement phase of the pentest

- Scope
- The testing window
- Contact information
- A “get out of jail free” card
- Payment terms
- Nondisclosure agreement clause

Information Gathering

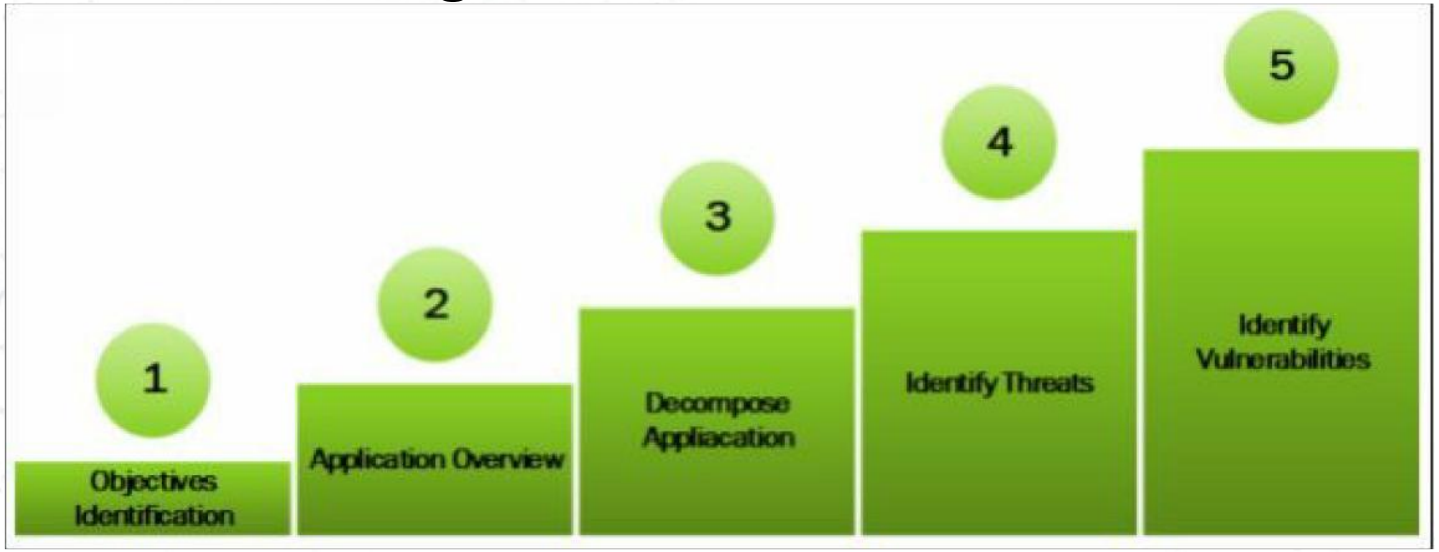
- Footprinting phase allows the attacker to gather the information regarding internal and external security architecture.
- Learning as much as possible about the target
- Time consuming. May take weeks or months to complete
- To save time some information can be provided such as IP addresses

Penetration Testing- Scanning

- Attacker use this to get an understanding about the network
- Dive deeper into the network
- Look for valuable data and services
- Specific IP addresses

Threat Modeling

Threat Modeling is the process or approach to identify, diagnose, and assist the threats and vulnerabilities of the system. It is an approach to risk management which dedicatedly focuses on analyzing the system security and application security against security objectives. This identification of threats and risks helps to focus and take action on an event to achieve the goals.



Vulnerability Analysis

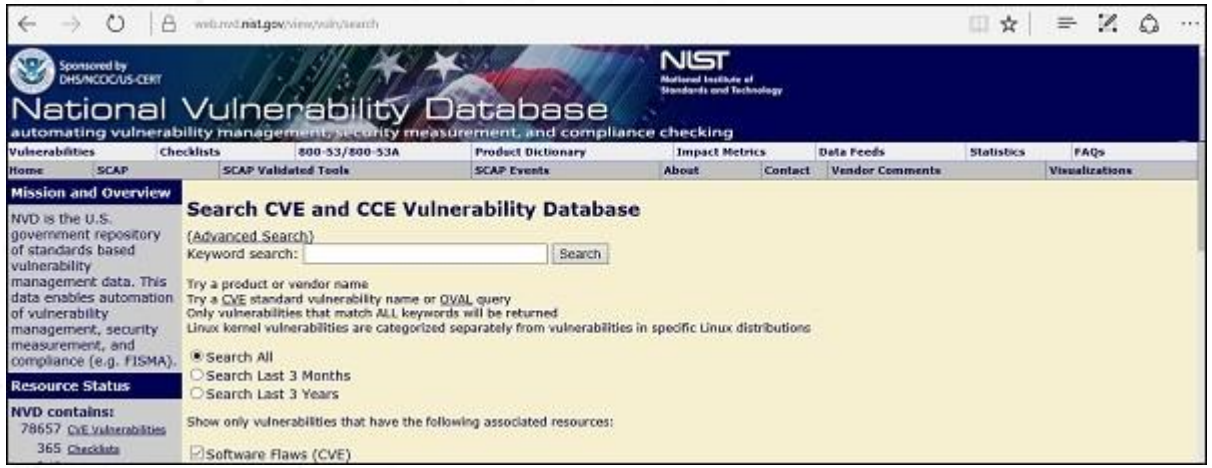
- Vulnerability Assessment can be defined as a process of examination, discovery, and identification of system and applications security measures and weaknesses.
- Vulnerability assessment also helps to recognize the vulnerabilities that could be exploited, need of additional security layers, and information's that can be revealed using scanners.

Penetration Testing- Gaining Access

- Maintain access once you have gained access
- Escalate the privileges to the Administrator level

Exploitation

- The act of exploiting the vulnerability in the target system. This is may be the most desired component for most of the pentesters.



Penetration Testing- Exploitation

- Launch exploits such as webserver attacks, buffer overflows and cross-site scripting
- Install a rootkit so the Ethical Hacker can access the system anytime

Reporting

- This is the final phase of penetration testing.
- Results of the pentesting are presented in the report.
- Can contain an executive summery.
- The vulnerabilities may be categorized as High, Medium and Low.

Understanding Penetration Testing

- Constant vigilance
- Patch and configuration management
- Monitor system defenses
- Securely configure OS and other applications
- Employment training
- End-point protection as the conventional perimeter has extended to the end users in the new work from home scenarios

The true story..

- An attacker may be able to breach the network defenses and steal data.
- Test your defenses to see how your system performs under an attack
- Do not wait until a real breach and face the consequences

Penetration Testing

- Proactive security assessment
- Tests systems by simulating attacks
- Review policies and procedures

Ethical Hackers

- Also known as white hat hackers
- Example. Members from CERT's
- Examines many ways how a breach can occur
- Uses the techniques and tools as a black hat hacker

Penetration Testing help to answer following questions.

- Do we have any unnecessary services running?
- Are social engineering techniques effective?
- What are the exploitable vulnerabilities?
- Are antimalware signatures up to date?
- Are the operating system patches current?

Risk

- Conducting a thorough Ethical Hacking exercise will help to identify risks to the organization.
- Risk is when a person, place or thing is open or exposed to harm which can result in injury, death or destruction.
- Organizations carry out risk analysis to consider potential threats such as cyber attacks

Manage Risk

- Organizations implement methods to manage risks and reduce the potential for harm
- The goal is to reduce the risk to protect the assets which are tangible and intangible items that can be assigned a value
- Tangible assets example. Laptop, printer
- Intangible assets example. Data, Trade secret

Risk = Threats x vulnerability

Defining Risk

- Threats may exist, but if there is no vulnerability there is no risk.
- Correspondingly if there is a vulnerability but no threat there is no risk.

Defining Threat

- Anything that can exploit a vulnerability intentionally or accidently , resulting in damaging or destroying an asset.
- Something that might happen is difficult to control
- May include disgruntled employee, hacker, nature

Defining Vulnerability

- A security flaw or weakness in a system that can be exploited by a threat to gain unauthorized access to an asset.
- Example. Connecting a system to Internet can represent a vulnerability if the system is unpatched.

Footprinting and Reconnaissance

- Thorough information gathering exercise
- First phase of ethical hacking
- Learning as much as possible about the target
- Things to look for include open ports and services, remote access capabilities and what security mechanisms in place
- Time consuming

Reconnaissance

- Gathering information about the location of a target by scouting or by setting up a covert observation posts.



Objectives of Footprinting



TO KNOW SECURITY POSTURE



TO REDUCE THE FOCUS AREA



IDENTIFY VULNERABILITIES



DRAW NETWORK MAP

Sequence of steps



- Gather information
- Locate the network range
- Discover active machines
- Determine Operating systems
- Define running services
- Map the network

Where to find information

- Use public resources
- Web sites, directories, email addresses, job sites, social networking
- Whois information – https://lookup.icann.org/en,whois.domaintools.com, https://www.domains.lk/
- Logical Side
- Network architecture, defense mechanisms, operating systems and applications
- Using websites like netcraft.com help you to find the OS used by targeted organization

How to start.



- Who is the target?
- What is the target?
- Where is the target?
- When is the best time for attack?
- How? Evident after recon

Document the findings



- Help in developing the best method of attack.
- Develop a template and record results
- Template may include the following.

Physical location, website URL, social networking data, IP address range, email address schema, Defensive devices ..etc

Job Postings

- Vulnerabilities
- Linux and Windows AD
- HP Comware



SYSTEM ADMINISTRATORS

SAKS caters a diverse portfolio of clients with services in Contact Center, Finance & Accounting, Research & Analytics, Software Development, and Data Analytics.

We are looking for *two (02)* reliable, proactive, and experienced professionals with a strong team spirit for our IT operations team.

SOME OF THE THINGS YOU WOULD BE DOING

- Administer and operate IT infrastructure (including Virt / Net aspects)
- Ensure service levels and availability
- Provide IT support for all business functions
- Help evolve and grow SAKS IT architecture
- Maintain ISO 27001 ISMS compliance across SAKS

YOU SHOULD HAVE

- **Advanced Diploma-level** ICT education ***with*** one of RHCSA, CCNA, MCSA (Windows Server) **certifications**
- **Three (03) years** of relevant industry experience, including:
  - Advanced TCP/IP networking (*e.g.,* with VLANs, switching, etc.)
  - Windows Active Directory administration
  - Linux command-line basics
  - Scripting / coding basics
- Willingness to work on a **shift-basis** (because SAKS is a 24x7 operation)

IT WOULD BE NICE IF YOU HAVE

- HP Comware experience
- Advanced VoIP networking experience
- Linux system administration experience
- Infrastructure automation experience (*e.g.,* Puppet / Chef / Ansible)
- ISO 27001 or similar InfoSec standard awareness

Competitive Intelligence



Using competitive intelligence can be a great nontechnical approach for footprinting and reconnaissance



It is different to industrial espionage

Google Hacking

- Googles web crawling bot are called Googlebots
- Detect new and updated pages
- Google Advanced search
- https://www.google.com/advanced_search

- Visit Google Hacking Database(GHDB) popularized by Johnny Long
- Single word vs combined words
- Searches are not case sensitive
- If a space exists in the search term use “ ” or use a period .
- Intitle:”index of”
- Intitle:index.of

Google Advance Search Operators

Advanced Search Operators	Description
site :	Search for the result in the given domain
related :	Search for Similar web pages
cache :	Display the web pages stored in Cache
allintext :	Search for websites containing a specific keyword
intext :	Search for documents containing a specific keyword
allintitle :	Search for websites containing a specific keyword in the title
allinurl :	Search for websites containing a specific keyword in URL

Google Hacking-Demo



- Try allintext:username filetype:log
- Try allintext:NIC filetype:xls site:.lk
- If you want to find ftp servers intitle:”index of” inurl:ftp
- allintext:SDN filetype:ppt site:.edu
- allintext:NIC filetype:xls site:.lk
- db_password filetype:env
- Look for vulnerability reports on the Internet
- intitle:”report” (“qualys” | “nessus” |”acunetix”) filetype:pdf



- https://survey.gov.lk/sdweb/pdf/documents/NVQ_%201500_LIST.pdf

- allintext:NIC site=.lk filetype=.xls

Collect Location Information



- You can collect local information like the physical location of headquarters with the surrounding, the location of branch offices and other related information from online location and map services.
- Google Earth
- Google Map
- Bing Map
- Wikimapia
- Yahoo Map
- Other Map and Location services

Search Engines

- Pipl search
- Using search engines and Google Hacking can help uncover security holes, advisories, and server vulnerabilities

Social Engineering

- Influencing someone into giving up information
- Can result in identity theft and data leakage
- A major threat to the security of an organization
- Social Engineers can include hackers, scammers, salespeople, or ordinary people
- Can be accomplished through telephone, online, dumpster diving, shoulder surfing and simple persuasion



Information Gathering

- Eavesdropping
- Persuasion
- Phishing
- Pharming
- Impersonation
- Social Media



Tracking on-line reputation

- Google image search
- Images.google.com
- Google alerts
- www.google.com/alerts
- Twitter alerts

Email

- Compromised email addresses linked with identity theft
- Target for spear phishing
- Threat for the contacts of the e-mail account
- How to find an email address?
- Email Forgery
- It appears to be coming from a valid source
- The From field is spoofed
- Sender Policy Framework(SPF)
- An SPF record is an extension of SMTP
- It prevents spammers from forging the From fields in email messages
- User education

Investigating Email

- Email Headers
- Tell the story of the journey
- Include all validation checks
- Read from the bottom up
- How to get email headers
- https://www.whatismyip.com/email-header-analyzer/



Return-Path: <bogdan@fx.ro>
Received: from srv01.advenzia.com (root@localhost)
by emailaddressmanager.com (8.11.6/8.11.6) with ESMTP id i2OApwQ14083
for <support@emailaddressmanager.com>; Wed, 24 Mar 2004 10:51:58 GMT
X-ClientAddr: 193.231.208.29
Received: **from** corporate.fx.ro (corporate.fx.ro [193.231.208.29])
by srv01.advenzia.com (8.11.6/8.11.6) with ESMTP id i2OApvs14078
for <support@emailaddressmanager.com>; Wed, 24 Mar 2004 10:51:57 GMT
Received: from mail.fx.ro (mail3.fx.ro [193.231.208.3])
by corporate.fx.ro (8.12.11/8.12.7) with ESMTP id i2OAtxBr025924
for <support@emailaddressmanager.com>; Wed, 24 Mar 2004 12:55:59 +0200
Received: from localhost.localdomain (corporate2.fx.ro [193.231.208.28])
by mail.fx.ro (8.12.11/8.12.3) with ESMTP id i2OAtoQe006624
for <support@emailaddressmanager.com>; Wed, 24 Mar 2004 12:55:50 +0200
Date: Wed, 24 Mar 2004 12:55:50 +0200
Message-Id: <200403241055.i2OAtoQe006624@mail.fx.ro>
Content-Disposition: inline
Content-Transfer-Encoding: binary
MIME-Version: 1.0
To: support@emailaddressmanager.com
Subject: How to read email headers
From: bogdan@fx.ro
Reply-To: bogdan@fx.ro
Content-Type: text/plain; charset=us-ascii
X-Originating-Ip: [80.97.5.101]
X-Mailer: FX Webmail webmail.fx.ro
X-RAVMilter-Version: 8.4.3(snapshot 20030212) (mail)
Status:

Website Mirroring

- Download the entire website
- Obtain emails,phone numbers and other information
- See concealed comments that hold information like passwords or links to protected content
- Tools include HTTrack, Wget, Web Data Extracter

Website traffic monitoring

- Check the statistics of websites
- ranking of the targeted website
- geographical view to the user from all over the world
- number of worldwide users, Daily time on site

Tools	URL
Monitis	http://www.monitis.com/
Web-stat	https://www.web-stat.com/
Alexa	https://www.alexa.com/

OSINT Tools

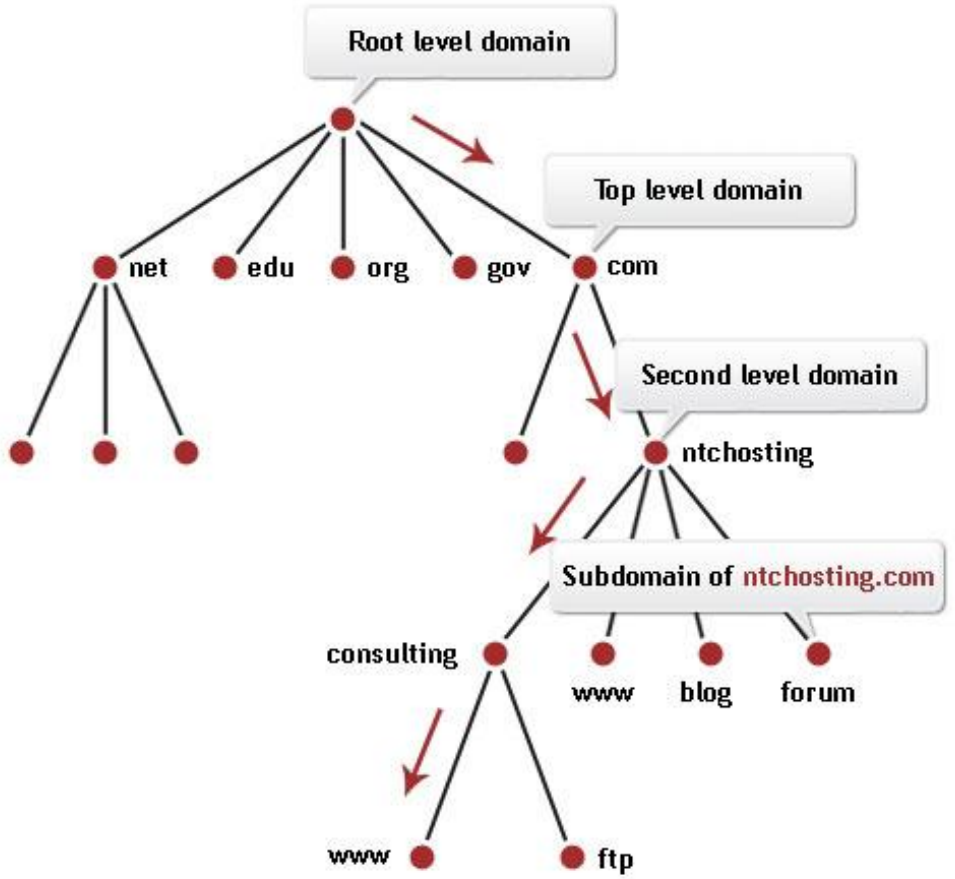
- Open-source intelligence gathering tool
- https://osintframework.com/
- Generates a more targeted discovery
- Maltego -https://www.youtube.com/watch?v=mUbqm8ZP-oo
- Community version and paid commercial version
- Included in Kali Linux
- Harvests domain names, whois information and ip addresses
- Person specific information websites and linked companies

Other tools

- Shodan- devices connected to the Internet
- Metagoofil (Kali)is an information gathering tool designed for extracting metadata of public documents (pdf,doc,xls,ppt,docx,pptx,xlsx) belonging to a target company.
- FOCA (Fingerprinting Organizations with Collected Archives) is a tool used mainly to find metadata and hidden information in the documents its scans. These documents may be on web pages and can be downloaded and analyzed with FOCA
- theHarvester(Kali) – Harvests info from public sources

Domain Name System

- DNS converts host names to an IP address.
- DNS uses port 53 over UDP or TCP
- TCP only used for zone transfer
- DNS Hierarchy is a tree like structure



DNS Footprinting

- DNS lookup information is helpful to identify a host within a targeted network.

Record Type	Description
A	The host's IP address
MX	Domain's Mail Server
NS	Host Name Server
CNAME	Canonical naming allows aliases to a host
SDA	Indicate authority for the domain
SRV	Service records
PTR	IP-Host Mapping
HINFO	Host Information

Multiple DNS threats

- Zone file compromise
- Flood Attack
- Cache Poisoning
- DNS Footprinting- find information managed by the SOA
- A Start of Authority record is a type of resource record in the Domain Name System (**DNS**) containing administrative information about the zone, especially regarding zone transfers

Good practice





Restrict zone transfers to authorized servers



Deny all inbound connection requests to TCP port 53



Consider using DNS Security

Ping and Tracert

- Ping
- Utility used to test for reachability using ICMP
- Tracert in windows
- Traceroute in Linux –sudo traceroute –I www.isc2.org
- Traces the route and provides the path and transit times
- Returns the FQDN and IP address of each gateway
- Help build the path of a network

nslookup

- Use to diagnose Domain Name System
- Part of the OS
- Non interactive & interactive modes

Domain Information Groper-dig



- Native to Linux
- Demo on Kali

Way back machine

- Visit http://web.archive.org/
- Search for a target website
- Select year from the calander
- You can get snapshot of the website on a specific date
- Check cert.gov.lk on the Way back Machine

Mitigations for Footprinting

- Don’t discuss confidential information online
- Use separate emails for business and personal work
- When posting pictures disable geotagging
- Monitor for scanning activity
- Shut down all unnecessary services
- Properly dispose of all printed information-shredding
- Avoid revealing sensitive information in Annual reports, Press releases
- Education, training and awareness of footprinting, impact and countermeasures to employees of the organization



Thank You…

Questions?